



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

CyberSecurity

2 - “Overview: Main Concepts and Terminology” *[Chapter 1]*

Gabriele D'Angelo <g.dangelo@unibo.it>

<https://www.unibo.it/sitoweb/g.dangelo/en>

Outline



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- Computer Security **Concepts**
- **Threats, Attacks, and Assets**
- Fundamental Security **Design Principles**
- **Attack Surfaces and Attack Trees**
- Computer Security **Strategy**

Fundamental Questions



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA



Defining a Threat Model

The focus is on three **fundamental questions**:

- **what assets** do we need to **protect**?
- **how** are those assets **threatened**?
- **what** can we do to **counter those threats**?

Threat Model



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA



Informal Definition of Threat Model: Who is my enemy? What do we have to protect? What are the potential consequences of an attack of my system?

In cybersecurity, a **threat model** is a **structured way of identifying potential threats, vulnerabilities, and risks** to a system, application, or organization. It is a **systematic approach to understanding the possible attack vectors, threat actors, and the potential impact of successful attacks.** (definition provided by “claude.ai”, 04/03/2024)

Computer Security (NIST definition)



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA



This computer security definition says that it is impossible to have security if we are not able to guarantee the security baseline: CIA Triad (for some system is enough, for others we need to extend the security properties)

«The protection ~~afforded to~~ an automated information system ~~in order~~ ^{al fine}
^{garantita a}

^{di conseguire gli obiettivi previsti in materia di salvaguardia}
~~to attain the applicable objectives of preserving the~~ **integrity**,

availability and **confidentiality** of information system resources.»

- It includes hardware, software, firmware, information/data, and

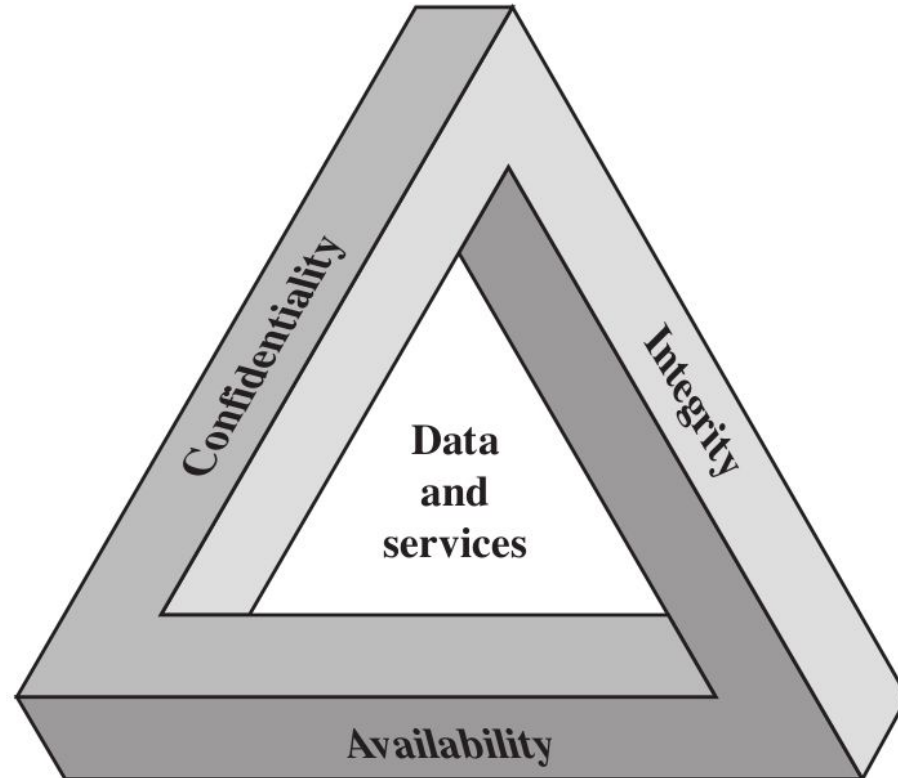
telecommunications

Prof Approach: Awareness, Problem Definition (every system is different: to define the problem, i need to define the security properties that i need to guarantee) and Solutions

The Security Requirements “CIA” Triad



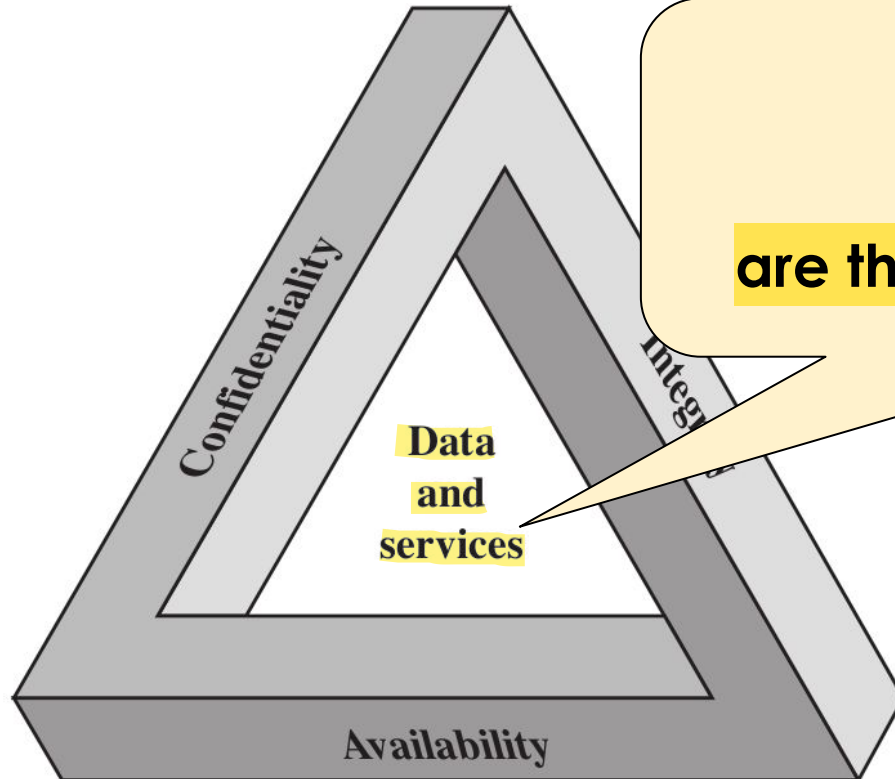
ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA



The Security Requirements “CIA” Triad



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA



In this approach

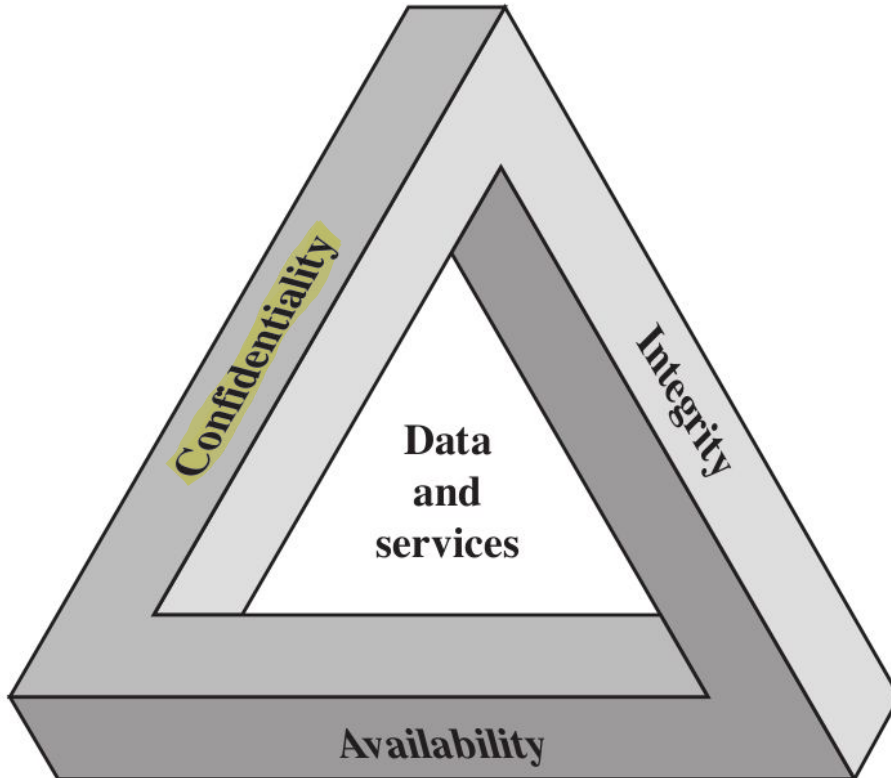
“data and services”

are the core elements to protect

The Security Requirements “CIA” Triad



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA



confidentiality divided in two different things:

- **data confidentiality**
- **privacy** (small subset of Cybersecurity)

1) Data Confidentiality: The "How"

Confidentiality is a technical obligation. Once an organization has your data, they have a duty to ensure that only authorized people can see it. If a hacker breaks into a server and steals a list of passwords, that is a loss of confidentiality, regardless of whether the data was "private" or not.

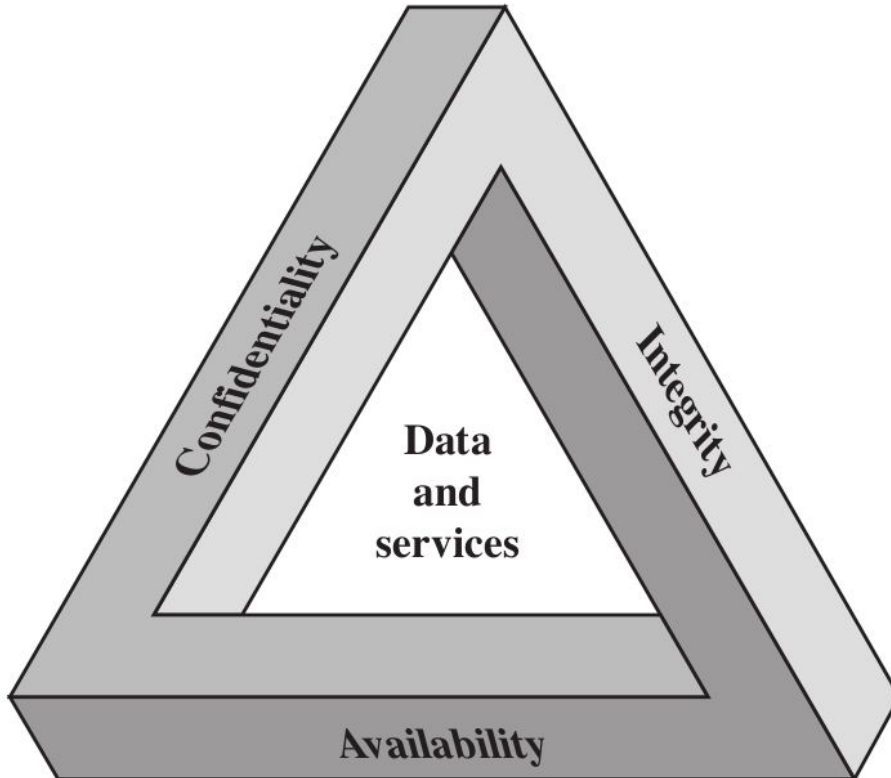
2) Privacy: The "What and Why"

Privacy is a policy and legal concept. It's about the choice of the individual. For example, if you choose to post your phone number on a public social media profile, you have waived your privacy for that data. However, the social media company still has a duty of confidentiality to ensure a random person can't log into your account and change that number. The Golden Rule: You can have confidentiality without privacy (e.g., a company keeps your secret data safe but sells it to advertisers anyway), but you cannot have privacy without confidentiality (if the data leaks, your privacy is gone).

The Security Requirements “CIA” Triad



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA



confidentiality

- data confidentiality
- privacy

example: logs of my activity on Unibo WiFi must be private

data confidentiality

private or **confidential**

information is not made

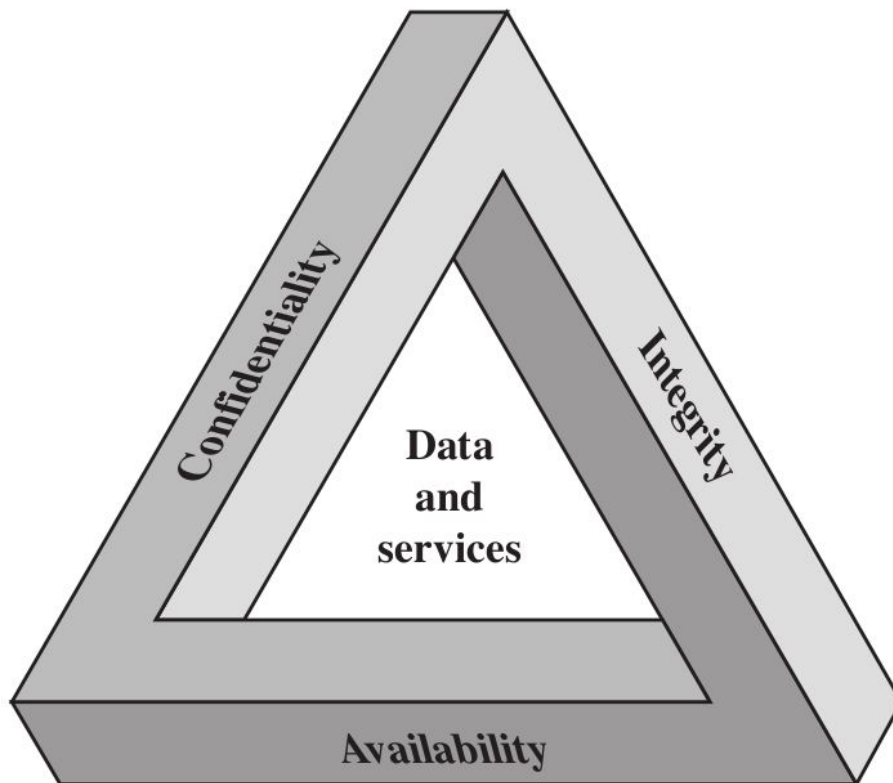
available or ^{divulgate} disclosed

to unauthorized individuals

The Security Requirements “CIA” Triad



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA



confidentiality

- data confidentiality
- privacy

example: I can
control the level of
visibility of my
pictures on Instagram

privacy

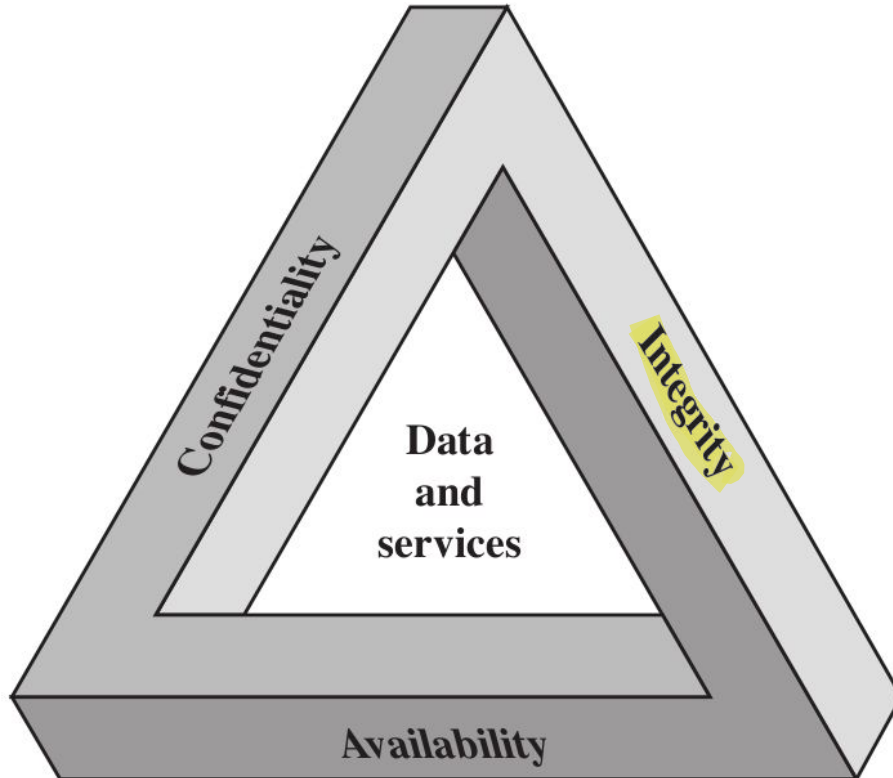
For some data can
be done, for other is
difficult to be done
or not be done

**individuals control what
information related to them
may be collected and stored,
by whom and to whom this
information may be disclosed**

The Security Requirements “CIA” Triad



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA



confidentiality

- data confidentiality
- privacy

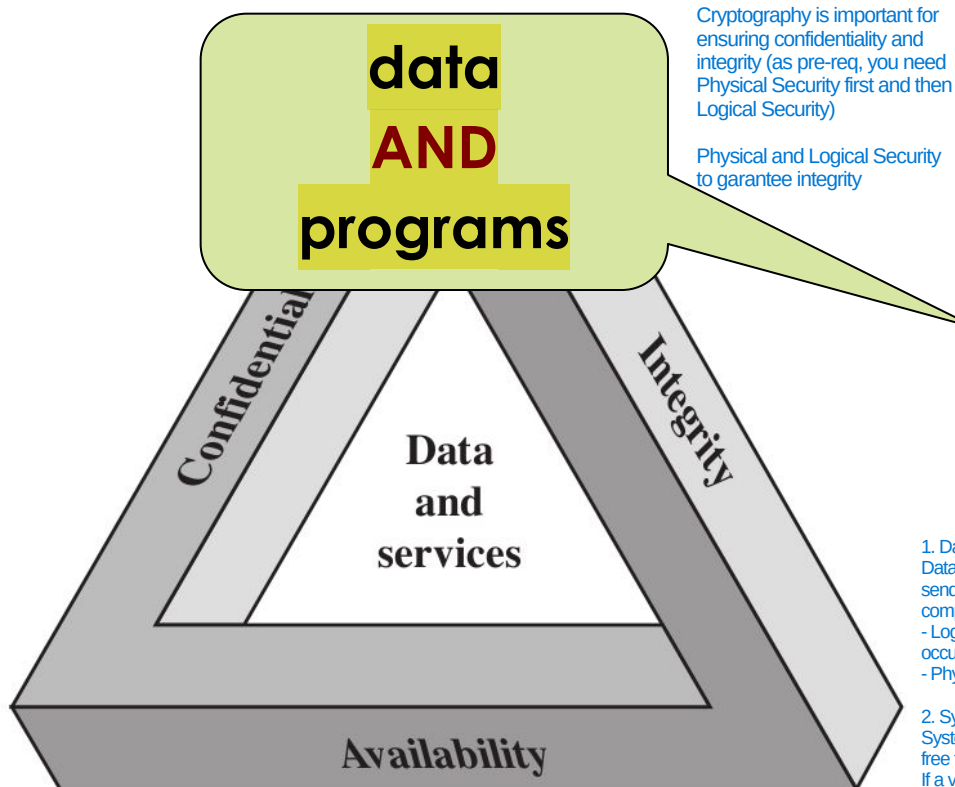
integrity

- data integrity
- system integrity

The Security Requirements “CIA” Triad



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA



confidentiality

- data confidentiality
- privacy

integrity

No unauth modification are done

- data integrity
- system integrity

1. Data Integrity: Is the information correct?

Data integrity ensures that information remains exactly as it was intended to be throughout its entire lifecycle. If you send a wire transfer for \$100 and a hacker changes the value to \$1,000 mid-transit, the data integrity has been compromised.

- Logical Integrity: Ensuring the data makes sense within a database (e.g., you can't have a "shipping date" that occurs before the "order date").

- Physical Integrity: Ensuring the data isn't corrupted by hardware failures or power outages.

2. System Integrity: Is the machine behaving?

System integrity means the system is "unimpaired." It is performing its scheduled tasks according to its specifications, free from unauthorized manipulation of its internal processes.

If a virus replaces a legitimate Windows system file with a malicious one, the system integrity is gone. Even if your personal files (data) haven't been touched yet, the environment they live in is no longer trustworthy.

The Security Requirements “CIA” Triad

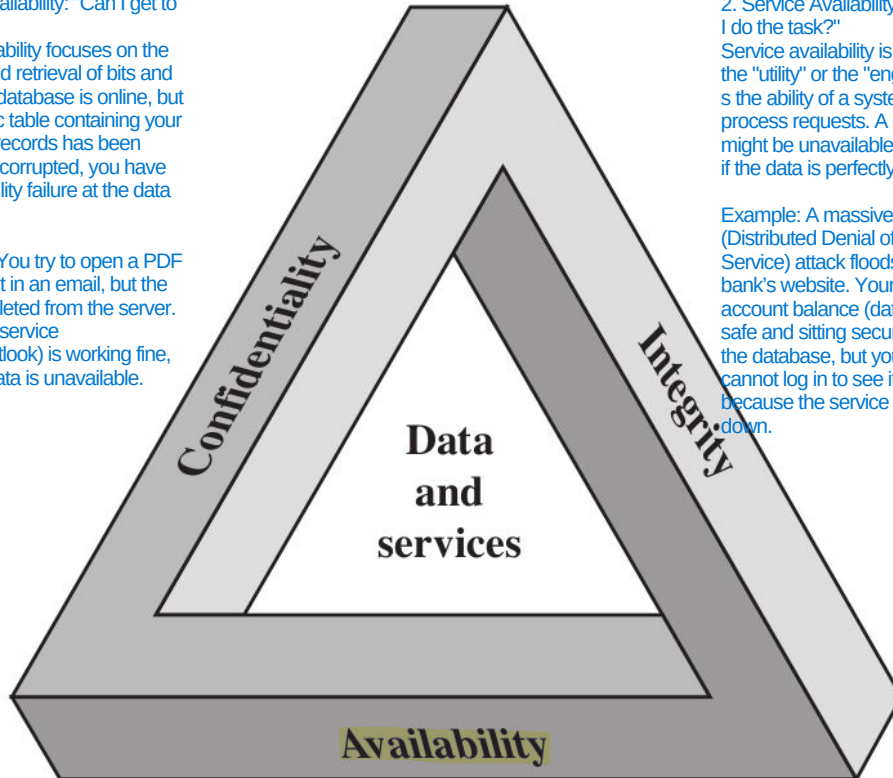


ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

1. Data Availability: "Can I get to my stuff?"

Data availability focuses on the storage and retrieval of bits and bytes. If a database is online, but the specific table containing your customer records has been deleted or corrupted, you have an availability failure at the data level.

Example: You try to open a PDF attachment in an email, but the file was deleted from the server. The email service (Gmail/Outlook) is working fine, but your data is unavailable.



2. Service Availability: "Can I do the task?"

Service availability is about the "utility" or the "engine." It's the ability of a system to process requests. A service might be unavailable even if the data is perfectly safe.

Example: A massive DDoS (Distributed Denial of Service) attack floods a bank's website. Your account balance (data) is safe and sitting securely in the database, but you cannot log in to see it because the service is down.

confidentiality

- data confidentiality
- privacy

integrity

- data integrity
- system integrity

availability

If there isn't, there is no security: if not available, customer cannot visualize its data

- data availability
- services availability

Key Security Concepts



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

Confidentiality

Integrity

Availability

Key Security Concepts



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

Confidentiality

Integrity

Availability

- Preserving authorized restrictions on **information access** and **disclosure**
- Including means for protecting personal **privacy** and proprietary information

Key Security Concepts



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

Confidentiality

Integrity

Availability

- Guarding against improper **information modification** or **destruction** (example: ransomware to attack the integrity of a system)
- **Comprende la garanzia** Including ensuring information (Non-repudiation is the legal and technical assurance that a particular person cannot deny having performed a specific action.) **non-repudiation** and **authenticity** (Authenticity is the guarantee that a message, transaction, or data bit actually comes from the source it claims to be from.)

Key Security Concepts



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

Confidentiality

Integrity

Availability

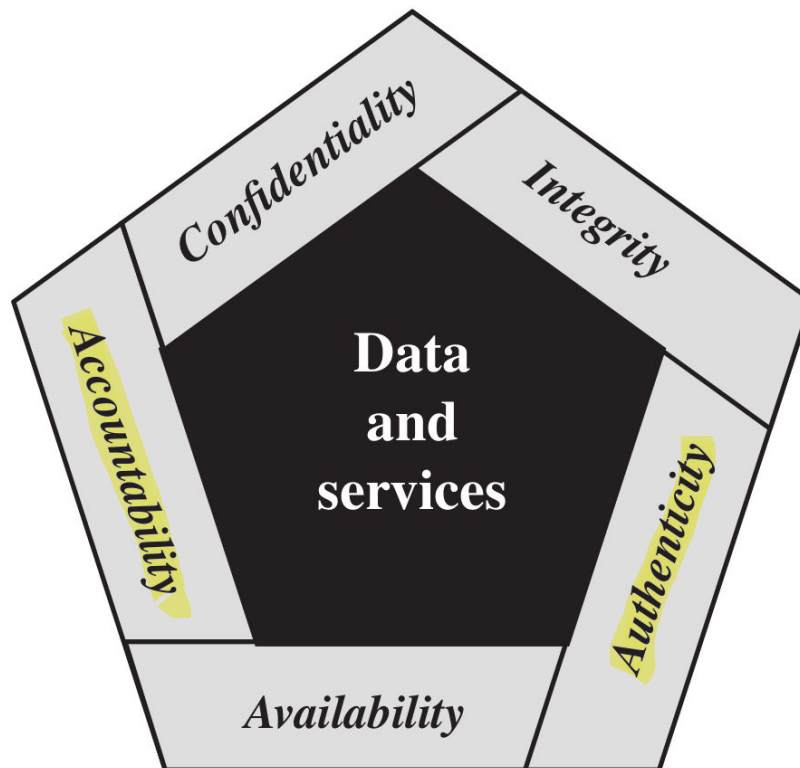
Garantire un accesso tempestivo
ed affidabile ai dati (e ai servizi)

Ensuring **timely** and
reliable access to and
use of **data** (and
services)

The Security Requirements



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA



Sometimes, the Triad is not enough. We need a Pentagon

Every single system has different requirements: in some cases Triad is enough, in other cases the Triad isn't enough and the Pentagon is enough, in other cases Pentagon isn't enough and we need something else.

Complexity of the system is higher in Pentagon Requirements, than in Triad

Key Security Concepts



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

Authenticity

1. Being Genuine (The "What")

This means the item or person is the real deal, not a replica, a fake, or an imposter.

- Data: A software update actually came from Apple, not a hacker.
- Person: The person logging into your bank account is actually you, not someone who found your password.

2. Being Able to be Verified (The "How")

A claim of being genuine is useless if you can't prove it. Verification requires a unique marker that is difficult to forge.

- In the physical world: A watermark on a passport or a handwritten signature.
- In the digital world: A Digital Signature or a Security Certificate (SSL/TLS).

3. Being Trusted (The "Result")

Once the verification succeeds, "Trust" is established. This allows the system to grant access or allow a transaction to proceed. If verification fails, the connection is untrusted and blocked.

Accountability

1. "Actions of an Entity"

An "entity" isn't always a person. It can be a user, a system process, or an automated bot. Accountability means every click, file deletion, or login attempt is captured.

2. "Traced Uniquely"

This is the most critical part. If three people share the password "Admin123", you have zero accountability. If a file is deleted, you know "an admin" did it, but you can't trace it uniquely to Bob, Sarah, or Mike. To have accountability, every entity must have a unique identity (UID).

3. "To That Entity"

This provides "Non-repudiation." It means the evidence is so strong that the entity cannot deny their involvement.

Key Security Concepts



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

Authenticity

- Property of being **genuine** and being able to be **verified** and **trusted**
- For example: confidence in the validity of a transmission, a message, or a message originator

Accountability

Key Security Concepts



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

Authenticity

Being able to guarantee the Accountability is incredibly hard, but it depends on your setup (company, internet, etc..)

Accountability

Accountability is a Trade-off with Privacy: Accountability often conflicts with privacy, creating a trade-off where increasing transparency for oversight reduces individual anonymity

Accountability is possible in organization or companies, but you have less privacy. It is difficult to have Accountability on the Internet due to anonymity, decentralization, and legal challenges

- The requirement for **actions of an entity** to be **traced uniquely to that entity**
- For example: ability to find the originator of a transmission, a message, or an action

Key Security Concepts

It is the process of using the gathered evidence (the audit logs and digital fingerprints) to hold a person or organization responsible in a court of law: Criminal Prosecution (This is when a government charges an individual with a crime), Civil Litigation (This is when one private party sues another) and Regulatory Action (This is when a government agency punishes a company for failing to follow security standards.)



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

Authenticity

Without Accountability is not possible to trace in which part of the system the fault has originated

While technical controls (like firewalls) physically stop an attack, deterrence aims to persuade a potential attacker that the effort isn't worth the risk.

Accountability

The requirement for **actions of an entity** to be **traced uniquely to that entity**

For example: *ability to find the originator of a **transmission**, a **message**, or an action*

I need Accountability

Necessary to support

non-repudiation, deterrence,

fault isolation, intrusion

detection and prevention...

recovery and legal action

I monitor the system, I check what happens. If something that is anomalous is happening on the system, I stop immediately what happens

Important to have in case of Failure of system protection (System compromised in real world, it happens). We can do Intrusion Detection and Prevention if we have Accountability

If things go wrong, you need to be able to decide what has been compromised and what not, and restore the things that has been compromised and maintain everything that has not been compromised

This classification is Qualitative, not quantitative enough
(we need a Quantitative Classification of Level of Impact)

Level of Impact

For being able to properly evaluate what is the Minimization of the risk, I need to be able to properly measure the Level of Impact (I can't only use this Qualitative Classification: I need a Quant one)



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

A compromise of a system or an attack on a system, can have a different level of impact

Low

The loss could be expected to have a **limited adverse effect** on organizational **operations**, organizational **assets**, or **individuals**

Moderate

The loss could be expected to have a **serious adverse effect** on organizational **operations**, organizational **assets**, or **individuals**

High

The loss could be expected to have a **severe or catastrophic adverse effect** on organizational **operations**, organizational **assets**, or **individuals**

Computer Security Challenges



The use of multiple cryptographic algorithms, security protocols, and tools in a single system creates significant challenges for security, interoperability, and performance. While combining techniques can sometimes strengthen security, it often results in increased complexity, potential vulnerabilities at interface points, and increased maintenance overhead.

- Computer security is **not as simple as it might first appear to the novice**

(for every single possible potential attack, you will need to be able to evaluate what is the probability of this specific attack and for each, you will need to be able to decide what is the level of impact of the specific attack that will be after that implemented)

- Potential attacks on the ^{system} security features must be considered

(Example: internet)

- Procedures used to provide particular services are **often counterintuitive**

Procedures used to provide security in legacy systems are frequently counterintuitive because they require retrofitting protections onto technology designed before modern threats existed. As systems grow over time, understanding how different parts provide specific features makes securing them difficult, often leading to the need for "compensating controls" rather than fundamental fixes.

- **Physical and logical placement** needs to be determined

if you don't know where the computation is executed, you have no idea of the integrity of the system

- **Multiple algorithms or protocols** may be involved

as it defines the perimeter, restricts lateral movement, and dictates the effectiveness of both tangible and digital controls. As physical and cyber domains merge, a unified strategy (addressing where a machine is located and where it resides on a network) is essential to mitigate risks like unauthorized access, device theft, and tampering.

Computer Security Challenges

when you want to
protect your system



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Attackers** only need to find a **single weakness** vulnerability in the system
- **Developers/administrators** need to find **all weaknesses**
- It is an **asymmetric game!** *(i.e. the players do not stand on equal ground)* the knowledge of the system is important,
so do not disclosure so much information
- The attacker can **combine multiple weaknesses** (in the real world, start with non-tech
vulnerability, humanware, then chain
of tech vulnerability)

Computer Security Challenges



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Users and system managers** tend to **not see the benefits** of security **until a failure occurs**
 - **good security is invisible** (linked to usability: if the security is invisible, it doesn't impact the work of the users)
 - **bad security is visible only after a security incident**
 - (usually) **good security does not generate revenues** (*i.e. if compared with advertisements, marketing etc.*)

Computer Security Challenges



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- Security requires **regular and constant monitoring** (*i.e. security is a process and not a product*) ... **security is costly!** Every single day, you will have to invest money and maintaining a proper security level
- It's often an **afterthought** to be incorporated into a system **after the design is complete** (*i.e. the Internet*) (Every time you have a system and you need to introduce security after the system design is completed, you have a big problem because it is impossible to have a proper level of security of something that has been already designed)
(Example: Two-level Authentication, too much time to login in an account than using only password, but you have more security) use protocol, to enhance security, on top of internet low protocols
- **Thought of as an impediment to efficient and user-friendly operation...**

(again) **security is a cost!**

Computer Security Terminology



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

The attacker reduce the costs for the attack in all way possibles, so the first phase of the attack is often automated (after the initial phases, the person is triggered)

or attacker

Adversary (threat agent): an **entity that attacks**, or is a **threat** to, a

system

(It isn't only about an attack that is implemented, it can be also about potential attack). We need to anticipate what will happen: so we will need to consider all the entities (example: person, algos, etc..) that can be interested in attacking our system.

The attacker is who is willing to violate the security policy. So, if you missed part that are important in the security policy, the violation of the security policy, very likely, cannot be flagged as an incident because it isn't considered in your security policy.

- **Attack**: an assault on system security that derives from an **intelligent**

(Example: Evade the Auth Mechanism)

threat; a deliberate attempt **to evade security services** and **violate**

the **security policy** of a system

a document or a bunch of different documents in which you define what is the level of security that you expect, what can be done inside your organisation and what cannot be done inside your organisation

(Example: can you play on Uni PCs during launch? It is defined in the security policy of the system)

Computer Security Terminology



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Adversary (threat agent)**: an entity that poses a **threat** to, a system
- **Attack**: an assault on system security that derives from an **intelligent threat**; a deliberate attempt **to evade security services** and **violate** the **security policy of a system**





In some cases the threat is not much “intelligent”

Example: some (not all) Denial of Service attacks
are rather simple (or stupid)

Example: Volumetric DoS: throw a lot of packets to the system to attack

or is a **threat** to, a

- **Attack**: an assault on system security that derives from an **intelligent threat**; a deliberate attempt **to evade security services** and **violate** the **security policy of a system**

Computer Security Terminology



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

In general, a Countermeasure is whatever can be done for being able to eliminating, preventing or minimizing the harm that it can caused

Countermeasure: an **action, device, procedure, or technique** that

reduces a threat, a vulnerability, or an attack by **eliminating** or

preventing it, by **minimizing** the **harm it can cause**, or by discovering

and reporting **it** so that **corrective actions can be taken**

the vulnerability

Very often, in CySec, it is not possible to eliminate the problem because we have constraints that make impossible to totally eliminate the problem. So, we prevent or minimize the Attack surface

Discover and Report the Vulnerability is a countermeasure (Discover and selling it to Vulnerability Broker isn't a countermeasure)

What happens if the attacker is able to exploit part of my Attack surface to compromise a specific service that is open to the external of my organisation? How much time for come back operational? This must be done every day for every risk that involves my organisation (this must be done for proper evaluating the assets that are inside my system)



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

Computer Security Terminology

- System: HW and SW used to provide some stuff/services of the business (can be a bunch of interconnected systems).
- Organisation: something related to Management of company and pays you money

- **Risk:** an **expectation of loss** expressed as the **probability** that a **particular threat** will exploit a **particular vulnerability** with a **particular harmful result**

When we are in charge of the CySec of the System, our job is minimizing the risk by means of whatever you want (i.e specific measures)

So, you can reduce impact and likelihood with tech and human solutions (example: filtering to reduce likelihood of download malware and education to reduce impact)

RISK
MATRIX

In some cases, very likely, you are going to use a combination of different mitigation technics.

For every single threat to your system, you must be able to properly classify this threat assigning a specific level of risk (cell of the risk matrix). Example: phishing email to download from outside the organisation a ransomware (likelihood almost certain, impact it encrypt all data and backups and the attacker asks money, you are with a critical risk). Based on the risk, you have to find a countermeasure to reduce the impact, so it reduces the risk (example: education of the employee, in this case)

Impact	Likelihood				
	Rare	Unlikely	Possible	Likely	Almost certain
Catastrophic	moderate	moderate	high	critical	critical
Major	low	moderate	moderate	high	critical
Moderate	low	moderate	moderate	moderate	high
Minor	very low	low	moderate	moderate	moderate
Insignificant	very low	very low	low	low	moderate

This table is the follow-up of the Classification of Level of Impact

Computer Security Terminology



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

It is Important both for tech purposes because i can defend only something that is indicated in the security policy, otherwise it is impossible for me to defend different parts of the organisation, but currently the Security policy is shaped by a lot of stuff that is, for example, not technical or it is imposed from outside (example: requirements of certifications)



Security policy: a **set of rules and practices** that specify **how a system**

or organization provides security services ^{with the aim} *(to protect sensitive and*

critical system resources)

Are you able to enforce the Security Policy? If you aren't able to enforce the Security policy with your boss, you have a problem, that typically happens. Enforcing the Security policy, will make you really unpopular inside the organisation (you will have tech and not tech problems (dealing with people))

Example: the **password policy** (i.e. **strong passwords and their**

expiration) of an organization is part of its **security policy**

Computer Security Terminology



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **System resource (asset)**: **data**; a **service** provided by a system; a **system capability**; an **item** of **system equipment**; a **facility** that houses system operations and equipment
- **Threat**: a **potential for violation of security**, which exists when there is a circumstance, capability, action, or event that could **breach security** and **cause harm**

Computer Security Terminology



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

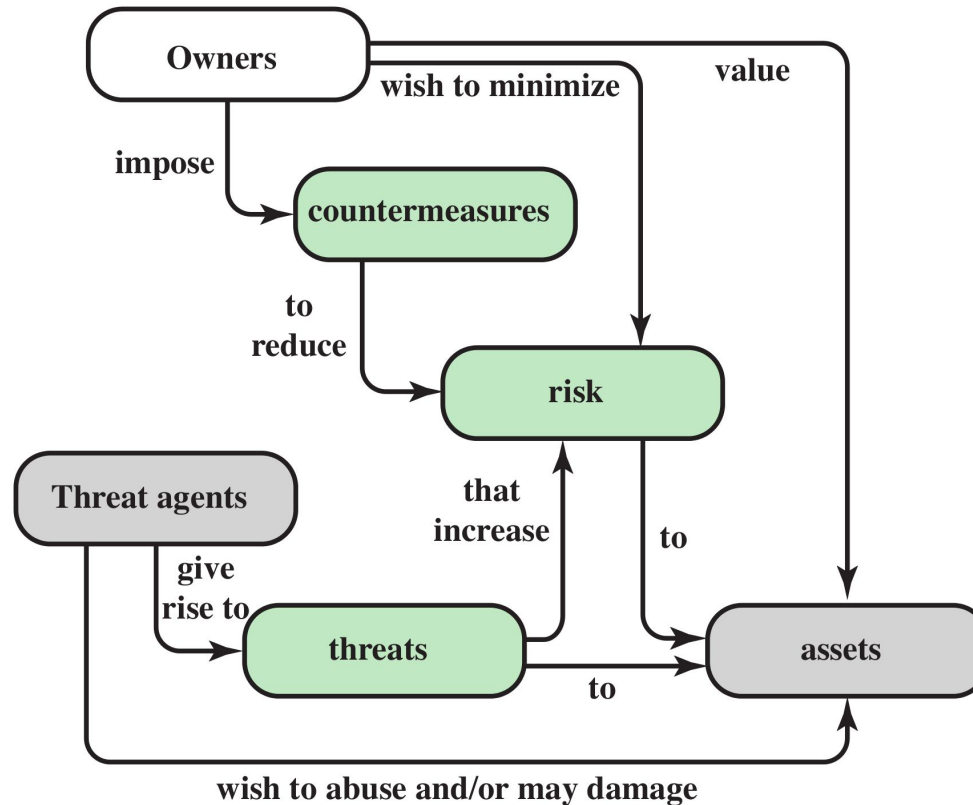
- **Vulnerability**: a **flaw** or **weakness** in a system's **design, implementation, or operation** and **management** that could be **exploited** to **violate the system's security policy**

Example: *there is a vulnerability in the **software** or the **users** are **not properly educated** to deal with email phishing*

Security Concepts and Relationship



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA



Vulnerabilities, Threats and Attacks



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Vulnerability** (of system resources):
 - **corrupted** (loss of **integrity**)
 - **leaky** (loss of **confidentiality**)
 - **unavailable** or very slow / **unresponsive** (loss of **availability**)

Vulnerabilities, Threats and Attacks



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Threats:**
 - capable of **exploiting vulnerabilities**
 - represent a **potential security harm**

Vulnerabilities, Threats and Attacks



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Attacks** (threats carried out):
 - **active** - attempt to **alter/affect** the **system resources**
 - **passive** – does **not** (directly) **affect** the **system resources**
 - **insider** or **outsider** (is it from an **internal** or **external thread**?)

More info about **active** and **passive** attacks in the following...

- **Attacks** (threats)
 - **active** - attempt to **alter/affect** the **system resources**
 - **passive** – does **not** (directly) **affect** the **system resources**
 - **insider** or **outsider** (is it from an **internal** or **external thread**?)

Countermeasures



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Any means** taken **to deal with a security attack**
 - **prevent**
 - **detect**
 - **recover**

Countermeasures



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Any means** taken to deal with a security attack

- prevent

- detect

- recover

Is that **always** possible?

Countermeasures



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Any means** taken to deal with a security attack

- prevent

- detect

- recover

No! That's why **detection** and **recovery** are of main importance

Countermeasures



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Any means** taken to deal with a security attack
 - prevent
 - detect
 - recover

Countermeasures



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- May **introduce new vulnerabilities**
- **Residual vulnerabilities** may **remain**
- The **goal** is to **minimize residual level of risk** to the assets
(that is to implement some kind of **mitigation**)

Threat Consequences



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Unauthorized disclosure** is a threat to **confidentiality**
 - **exposure**: *this can be **deliberate** or be the result of a human, hardware, or software **error***
 - **interception**: *unauthorized **access** to data*
 - **inference**: *e.g., traffic **analysis** or use of limited access to get detailed information*
 - **intrusion**: *unauthorized **access** to sensitive data*

Threat Consequences



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Deception** is a threat to either **system** or **data integrity**
 - **masquerade**: e.g., Trojan horse; or an attempt by an unauthorized user to gain **access** to a system **by posing as** an authorized user
 - **falsification**: the **alteration** or **replacement** of valid data or the **introduction** of false data
 - **repudiation**: an entity **deceives** another by falsely **denying responsibility** for an act

Threat Consequences



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Disruption** is a threat to **availability** or system **integrity**
 - **incapacitation**: a result of physical **destruction** of or **damage** to system hardware
 - **corruption**: system resources or services function in an **unintended** manner; **unauthorized** modification
 - **obstruction**: e.g. **overload** the system or interfere with communications

Threat Consequences



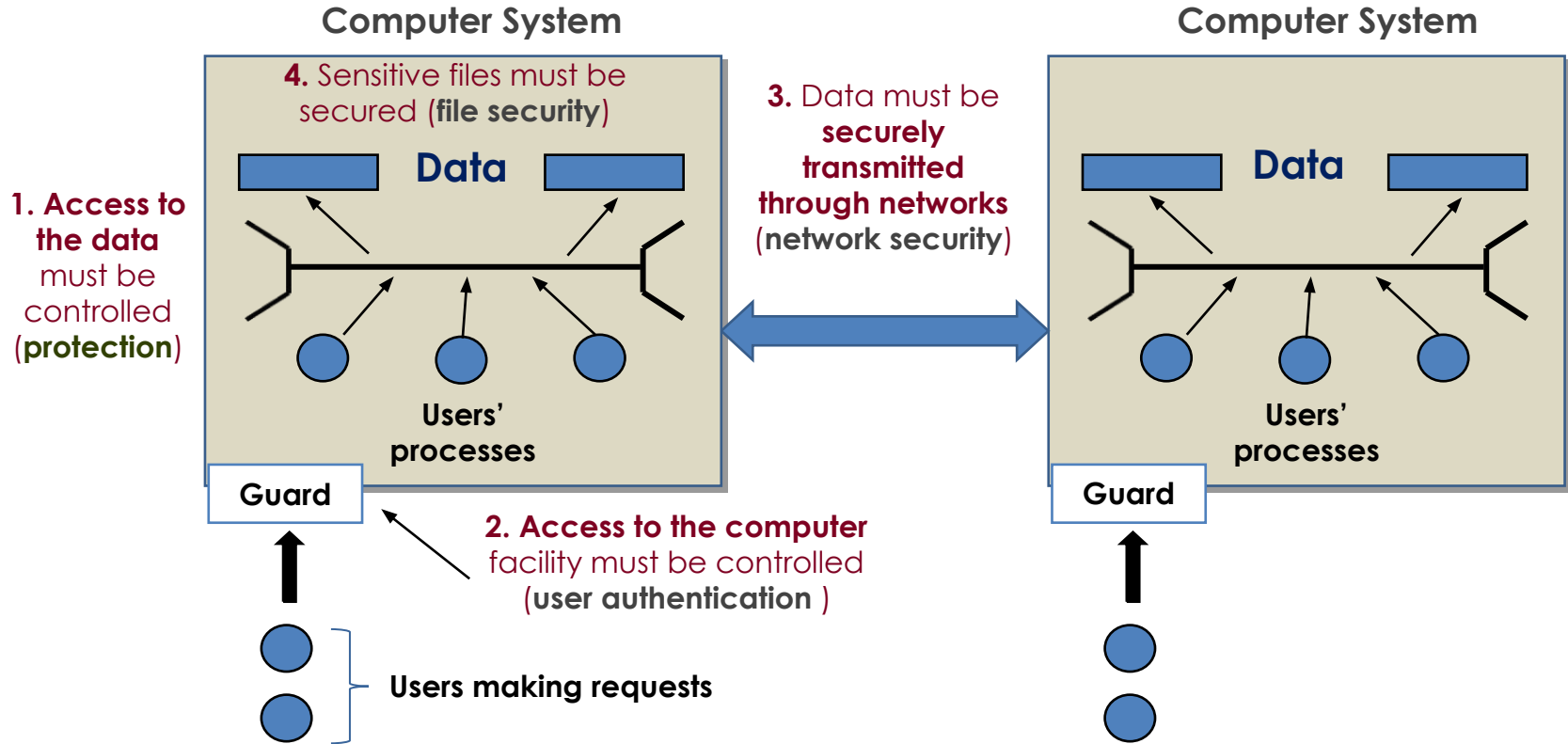
ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Usurpation** is a threat to **system integrity**
 - **misappropriation**: *an entity assumes **unauthorized** logical or physical **control** of a system resource*
 - **misuse**: *causes a system component to perform a function or service that is **detrimental to system security***

Scope of Computer Security



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA



Scope of Computer Security



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

	Availability	Confidentiality	Integrity
Hardware	Equipment is stolen or disabled, thus denying service	An unencrypted USB drive is stolen	
Software	Programs are deleted, denying access to users	An unauthorized copy of software is made	A working program is modified to cause it to fail or to cause it to do some unintended task
Data	Files are deleted, denying access to users	An unauthorized read of data is performed. An analysis of statistical data reveals underlying data	Existing files are modified or new files are fabricated
Communication Lines	Messages are destroyed or deleted. Communication lines or networks are rendered unavailable	Messages are read. Traffic patterns are observed	Messages are modified, delayed, reordered, duplicated. False messages are fabricated

Scope of Computer Security



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

	Availability	Confidentiality	Integrity
Hardware	Equipment is stolen or disabled, thus denying service	An unencrypted USB drive is stolen	
Software	Programs are deleted, denying access to users	An unauthorized copy of software is made	A working program is modified to cause it to fail or to cause it to do some unintended task
Data	Files are deleted, denying access to users	An unauthorized read of data is performed. An analysis of statistical data reveals underlying data	Existing files are modified or new files are fabricated
Communication Lines	Messages are destroyed or deleted. Communication lines or networks are rendered unavailable	Messages are read. Traffic patterns are observed	Messages are modified, delayed, reordered, duplicated. False messages are fabricated



Example: the ATM skimmers



Integrity



A working program is modified to cause it to fail or to cause it to do some unintended task

Existing files are modified or new files are fabricated

Messages are modified, delayed, reordered, duplicated. False messages are fabricated

Scope of Computer Security



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

	Availability	Confidentiality	Integrity
Hardware	Equipment is stolen or disabled, thus denying service	An unencrypted USB drive is stolen	
Software	Programs are deleted, denying access to users	Or encrypted!	
Data	Files are deleted, denying access to users		
Communication Lines	Messages are destroyed or deleted. Communication lines or networks are rendered unavailable	Messages are read. Traffic patterns are observed	Messages are modified, delayed, reordered, duplicated. False messages are fabricated

Sco

Hardware

Software

Data

Communication

MA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

egrity

program is
use it to fail or
to do some
ed taske modified or
fabricatede modified,
eordered,
lse messages
icated

Your personal files are encrypted!



Private key will be destroyed on
10/20/2013
12:37 PM

Time left
72 : 34 : 50

Your important files **encryption** produced on this computer: photos, videos, documents, etc. [Here](#) is a complete list of encrypted files, and you can personally verify this.

Encryption was produced using a **unique** public key [RSA-2048](#) generated for this computer. To decrypt the files you need to obtain the **private key**.

The **single copy** of the private key, which will allow you to decrypt the files, located on a secret server on the Internet; the server will **destroy** the key after a time specified in this window. After that, **nobody and never will be able** to restore files...

To obtain the private key for this computer, which will automatically decrypt files, you need to pay **300 USD / 300 EUR** / similar amount in another currency.

Click «Next» to select the method of payment.

Any attempt to remove or damage this software will lead to the immediate destruction of the private key by server.

[Next >>](#)

Your personal files are encrypted!

Your important files **encryption** produced on this computer: photos, videos, documents, etc. [Here](#) is a complete list of encrypted files, and you can personally verify this.

Encryption was produced using a **unique** public key [RSA-2048](#) generated for this computer. To decrypt the files you need to obtain the **private key**.

The **single copy** of the private key, which will allow you to decrypt the files, located on a secret server on the Internet; the server will **destroy** the key after a time specified in this window. After that, **nobody and never will be able** to restore files...

crypt files, you

immediate

Case Study: [WannaCry](#)

Private

Time left

72 : 34 : 50

Next >>

program is
use it to fail or
to do some
ed task

e modified or
fabricated

e modified,
eordered,
lse messages
icated

Sco

Hardware

Software

Data

Communication

Scope of Computer Security



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

	Availability	Confidentiality	Integrity
Hardware	Equipment is stolen or disabled, thus denying service	An unencrypted USB drive is stolen	
Software	Programs are deleted, denying access to users	An unauthorized copy of software is made	A working program is modified to cause it to fail or to cause it to do some unintended task
Data	Files are deleted, denying access to users	An unauthorized read of data is performed. An analysis of statistical data reveals underlying data	Existing files are modified or new files are fabricated
Communication Lines	Messages are destroyed or deleted. Communication lines or networks are rendered unavailable	Messages are read. Traffic patterns are observed	Messages are modified, delayed, reordered, duplicated. False messages are fabricated

Passive and Active Attacks



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Passive attacks** attempt to **learn** or make use of information from the system **but do not affect system resources**
 - **example**: eavesdropping/monitoring of transmissions
 - **difficult to detect**
 - emphasis is on **prevention** rather than detection
 - **two** main types (**message contents**, traffic **analysis**)

Passive and Active Attacks



ALMA MATER STUDIORUM
BOLOGNA

The transmission is **intercepted**

- **Passive attacks** attempt to compromise the system **but do not affect system resources**
 - **example**: eavesdropping/monitoring of transmissions
 - **difficult to detect**
 - emphasis is on **prevention** rather than detection
 - **two** main types (**message contents**, **traffic analysis**)

Passive and Active Attacks



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Passive attacks** attempt to **learn** or make use of information from the system **but do not affect system resources**
 - **example**: eavesdropping/monitoring of transmissions
 - **difficult to detect**
 - emphasis is on **prevention** rather than detection
 - **two** main types (**message contents**, **traffic analysis**)

Passive and Active Attacks



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Passive attacks** attempt to intercept information from a system **but do not affect system operation**
 - **example:** eavesdropping
 - **difficult to detect**
 - emphasis is on **prevention** rather than detection
 - **two** main types (**message contents**, **traffic analysis**)

This happens when the message
is transmitted “**in clear**”
(**not encrypted**)



Even when the messages are encrypted
it is possible to perform some **analysis**

For example: content **size**, **frequency**...

- **difficult to detect**
- emphasis is on **prevention** rather than **detection**
- **two** main types (**message contents**, **traffic analysis**)

Passive and Active Attacks



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Active attacks** involve **modification** of the data stream (or the attacked system)
 - the **goal** is to **detect** them and to **recover**
 - four main types:
 - **masquerade**
 - **replay**
 - **modification of messages**
 - **denial of service**

Passive



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

One **entity** pretends to be a
different entity

Example: a **user** or a **device**

- **Active attacks**

attacked

or the

- the **goal** is to **steal** them and to **recover**

- four main types:

- masquerade
- replay
- modification of messages
- denial of service

Passive and Active

- **Active attacks** involve the attacker's interaction with the attacked system)

- the **goal** is to cause some damage to the system
- four main types

- masquerade
- replay
- modification of messages
- denial of service

Passive capture of a data unit and its subsequent **retransmission** to produce an unauthorized effect:

Man-In-The-Middle (MITM) attack

Example: "Open sesame"

Passive and Active Attacks



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Active attacks**

attacked

- the s

- four main ty

- masquer

- replay

- modification of messages

- denial of service

I think that it is obvious

Example: *to change the IBAN
code in a bank transfer*

am (or the

Passive and Active Attacks



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Active attacks**

attacked system

- the **goal**

- four main

- masquerade
- replay
- modification of messages
- denial of service

An **interruption** in an authorized user's access to a computer network, typically one caused with malicious intent

Example: the Mirai botnet

Security Design Principles



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Economy of mechanism:** the design of security measures should be **as simple as possible** (*i.e. **simpler** to implement and to verify, **fewer** vulnerabilities*)
- **Fail-safe default:** access decisions should be based on **permissions** rather than exclusion (*i.e., the **default** is lack of access*)
- **Complete mediation:** every access should be checked against the **Access Control system** (*see Chapter 4*)

Security Design Principles



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Open design**: the design should be **open rather than secret** (e.g., *encryption algorithms*)
- **Separation of privileges**: **multiple privileges** should be required to achieve access to a restricted resource (or to complete some tasks)
- **Least privilege**: every user (or process) should operate **using the least set of privileges** necessary to perform a task (e.g., the sysadmin must **not** surf the Web using the administrator user)

Security Design Principles



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Least common mechanism**: a design should minimize the **functions shared** by different users/entities (*e.g., **sharing state** among different software programs*)
- **Psychological acceptability**: the security mechanisms should not **interfere** unduly with the work of users (*i.e. **user's acceptance** of security mechanisms*)

Security Design Principles



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Isolation:**
 - **public access** should be isolated from critical resources (*i.e., no connection between public and critical information*)
 - **users files** should be isolated from one another (except when desired)
 - the **security mechanism** should be isolated (*i.e., preventing access to those mechanisms*)

Security Design Principles



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Encapsulation**: similar to **object-oriented programming concepts** (*i.e., hide internal structures*)
- **Modularity**: development of security functions as **separate, protected modules** and use of a **modular architecture** (*for the mechanism design and implementation*)

Security Design Principles



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Layering (defense in depth)**: use of **multiple, overlapping** protection approaches (*e.g., multiple firewalls based on different technologies and approaches*)
- **Least astonishment**: a program or interface should always respond in a way that is **least likely to astonish a user** (*e.g., an error window that belong to what running program?*)

Security Mechanism



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- It is (or it should be) **designed to**:
 - **prevent** attackers from violating security policy
 - **detect** attackers' violation of security policy
 - **response** to **mitigate** attack
 - **recover**, continue to function **correctly** even if **attack succeeds**
- No single mechanism is able to support all services:
 - **Example**: *authentication, authorization, availability, confidentiality, integrity, non-repudiation*

Attack Surface



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- The **reachable** and **exploitable** vulnerabilities in a system:
 - **services** listening on the network
 - **services** that are **not protected by a firewall**
 - **software** that **processes incoming data** (i.e. e-mails, web pages, office documents, pdf, whatsapp messages...)
 - an **employee** (or a **subcontractor**) with **access to sensitive information**

Attack Surface



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- The **reachable** and **exploitable vulnerabilities** in a system:

- **services listening on the network**

“Open ports”: running processes using network sockets

- an employee (or a subcontractor) with **access to sensitive information**



A “**firewall**” is a software or hardware tool used to **restrict the network access to a system**

abilities in a system:

- **services** **listening on the network**
- **services** that are **not protected by a firewall**
- **software** that **processes incoming data** (i.e. e-mails, web pages, office documents, pdf, whatsapp messages...)
- an **employee** (or a **subcontractor**) with **access to sensitive information**



Its goal is to **permit authorized access** and to **deny unauthorized** (i.e., malicious) **attempts**

abilities in a system:

- **services** **listening on network**
- **services** that are **not protected by a firewall**
- **software** that **processes incoming data** (i.e. e-mails, web pages, office documents, pdf, whatsapp messages...)
- an **employee** (or a **subcontractor**) with **access to sensitive information**

Attack Surface



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- The **reachable** and **exploitable** vulnerabilities in a system:
 - **services** listening on the network
 - **services** that are **not protected by a firewall**
 - **software** that **processes incoming data** (i.e. e-mails, web pages, office documents, pdf, whatsapp messages...)
 - an **employee** (or a **subcontractor**) with **access to sensitive information**

Attack Surface



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

... but also **Application
Programming Interfaces (APIs),
SQL queries, web forms ...**

abilities in a system:

- **services** that are **protected by a firewall**
- **software** that **processes incoming data** (i.e. e-mails, web pages, office documents, pdf, whatsapp messages...)
- an **employee** (or a **subcontractor**) with **access to sensitive information**



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

Network Scanning



NMAP

Exposed attack surface

What is it?

Check it out!

T1

Attack Surface: **categories**



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- Three main **categories**
 - **network** attack surface (i.e. **network vulnerability**)
 - **software** attack surface (i.e. **software vulnerability**)
 - **human** attack surface (i.e. **social engineering**)
- Attack surface **analysis**
 - **assessing the scale and severity of threats** (i.e. to decide **how to allocate** the available resources)... it is **not easy**...

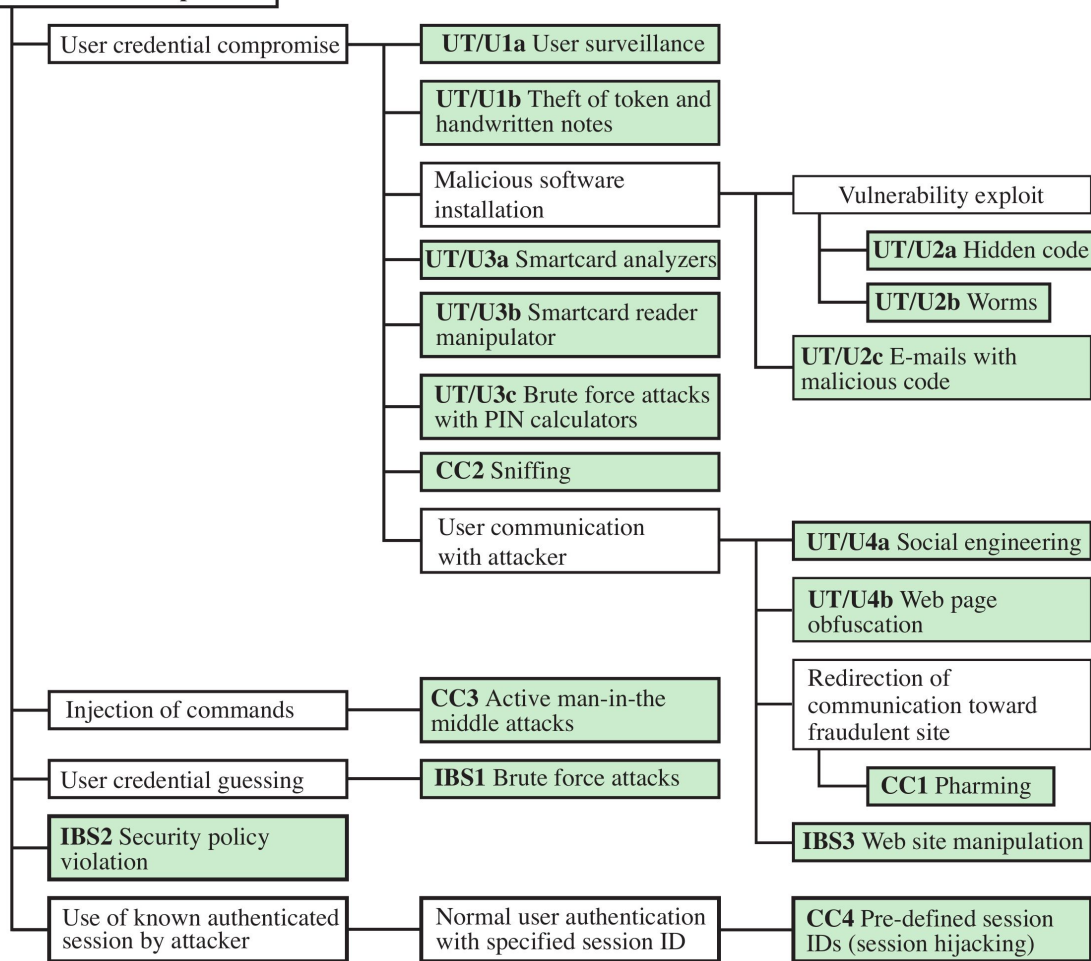
Attack Trees



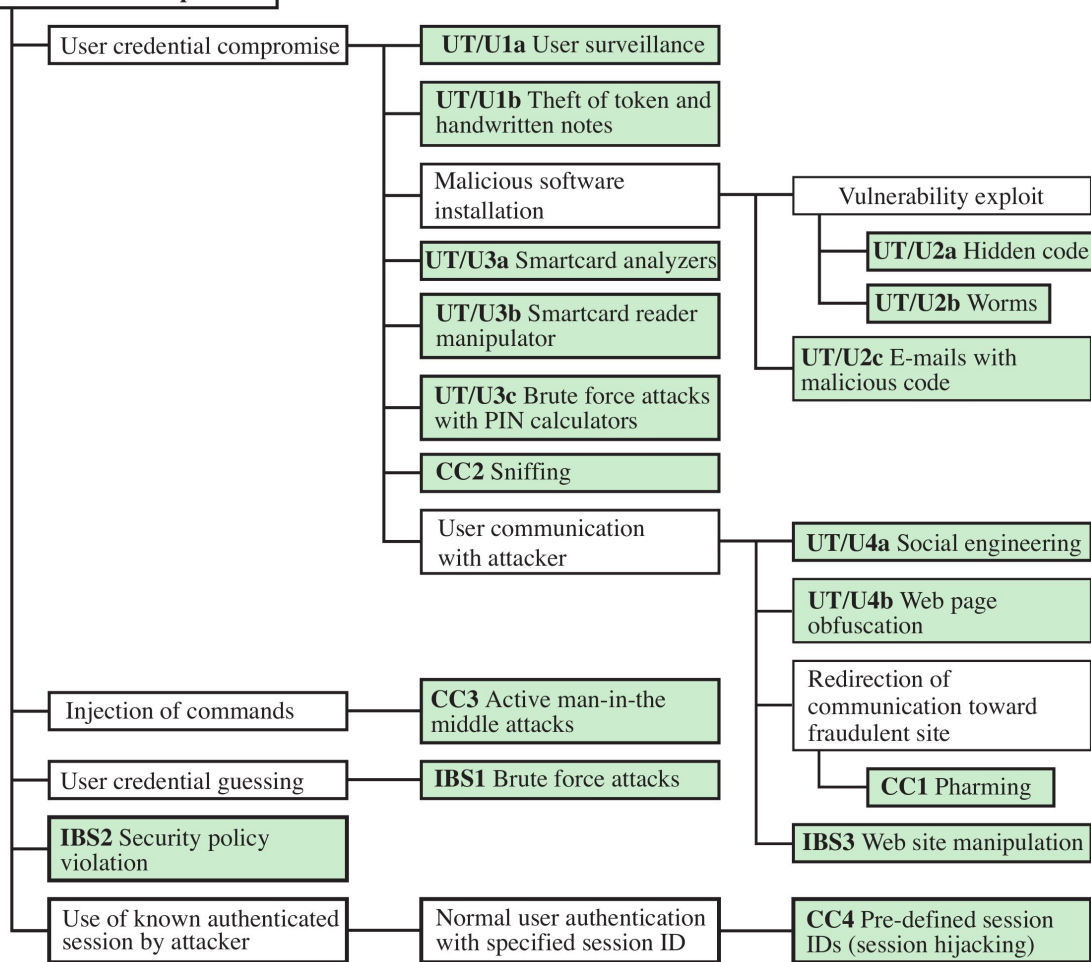
ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- **Attack trees** are often used to perform **attack surface analysis**
- An **attack tree** is a **branching, hierarchical** data structure that **represents a set of potential vulnerabilities**
- **Objective:** to effectively exploit the info available on **attack patterns**
(i.e. the methods used to find errors or problems in the systems)
- **Attack trees** can be used by the **security analysts** to **guide design and strengthen countermeasures**

Bank Account Compromise



Bank Account Compromise

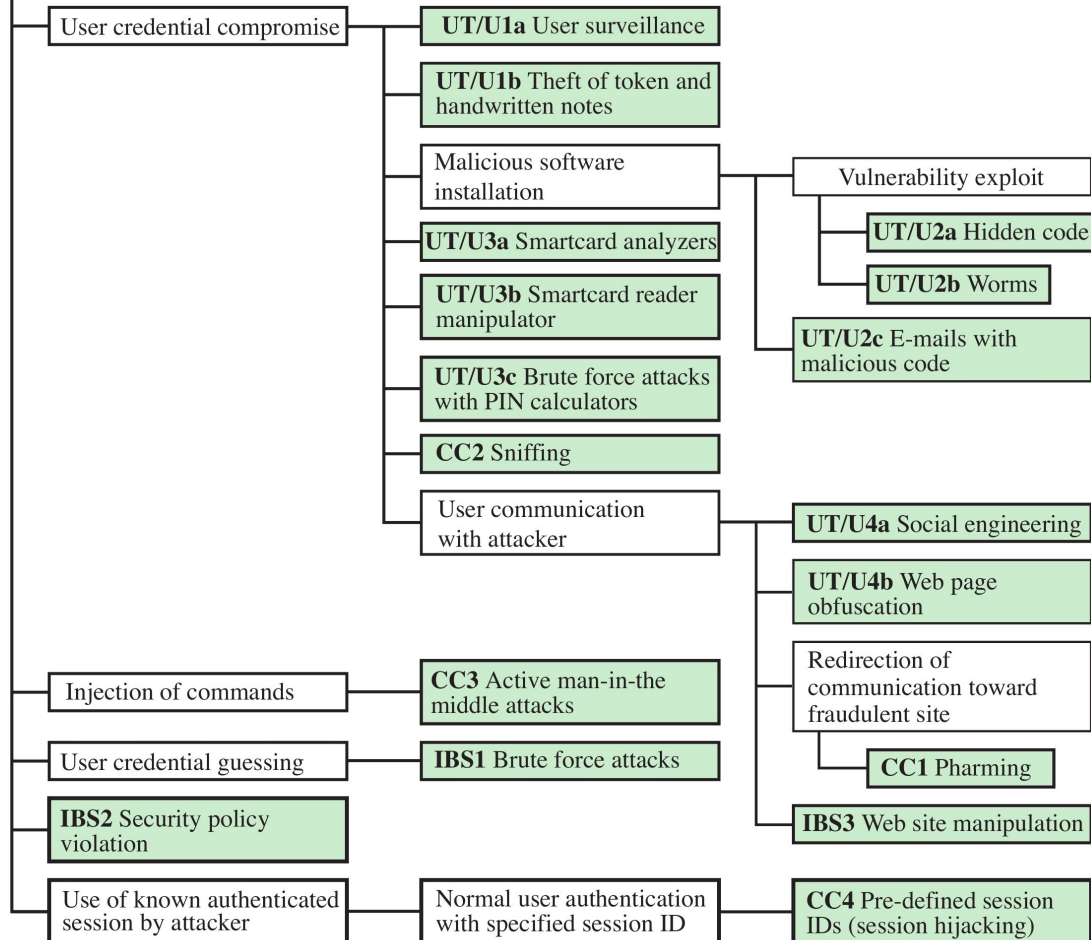


The goal is to compromise
an online bank account



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

Bank Account Compromise



The goal is to compromise
an online bank account

This can be done in many
different ways



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

Bank Account Compromise

User credential compromise

UT/U1a User surveillance

UT/U1b Theft of token and handwritten notes

Malicious software installation

UT/U3a Smartcard analyzers

UT/U3b Smartcard reader manipulator

UT/U3c Brute force attacks with PIN calculators

UT/U3d Sniffing

UT/U3e Communication hijacker

Vulnerability exploit

UT/U2a Hidden code

UT/U2b Worms

UT/U2c E-mails with malicious code

UT/U4a Social engineering

For example:
**compromising the
credentials**

Injection of

User creden

IBS2 Security violation

Use of known authenticated session by attacker

with specified session ID

CCITT defined session IDs (session hijacking)

The goal is to compromise an online bank account

This can be done in many different ways



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

Bank Account Compromise

User credential compromise

UT/U1a User surveillance

UT/U1b Theft of token and handwritten notes

or **guessing** them
(i.e., weak passwords)

Injection of command

CC3 Active man-in-the middle attacks

User credential guessing

IBS1 Brute force attacks

IBS2 Security policy violation

Use of known authenticated session by attacker

Normal user authentication with specified session ID

UT/U4a Social engineering

UT/U4b Web page obfuscation

Redirection of communication toward fraudulent site

CC1 Pharming

IBS3 Web site manipulation

CC4 Pre-defined session IDs (session hijacking)

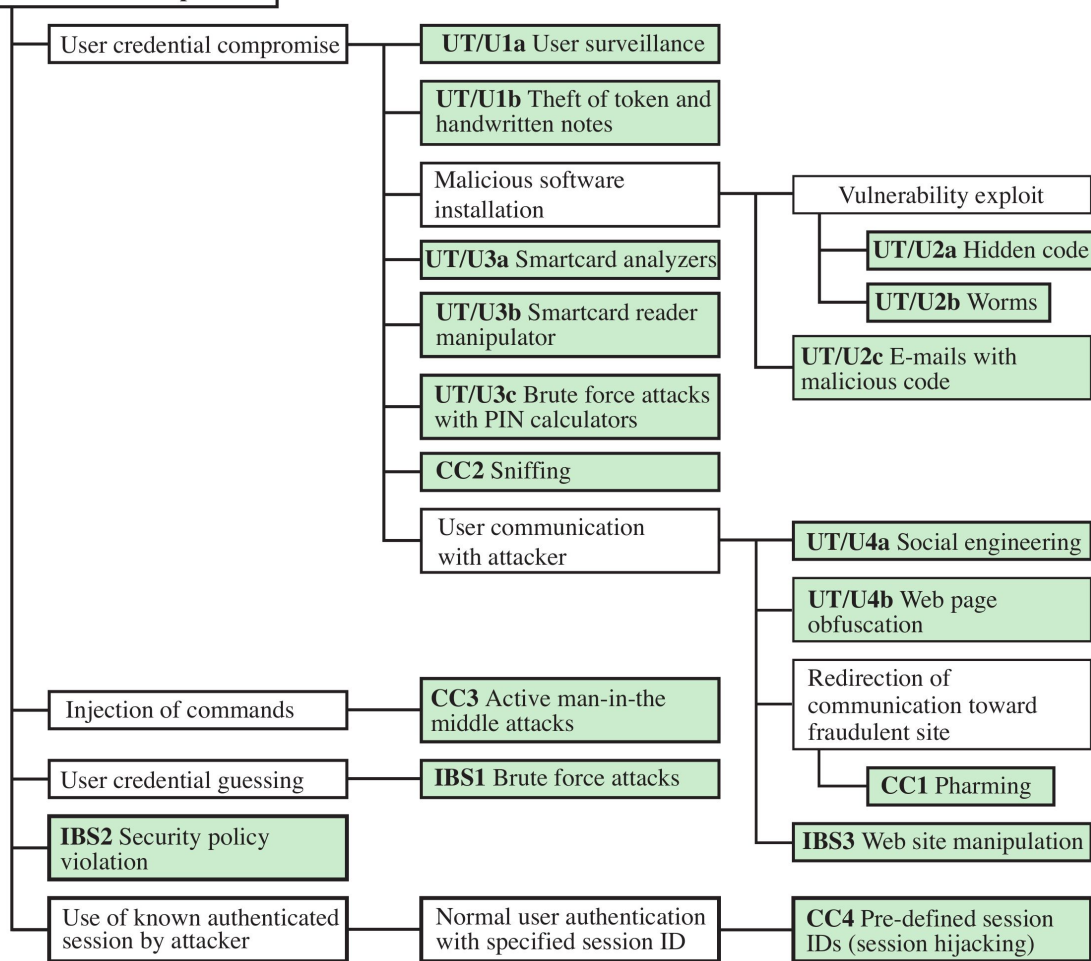
The goal is to compromise an online bank account

This can be done in many different ways



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

Bank Account Compromise





ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

CyberSecurity

Gabriele D'Angelo

<g.dangelo@unibo.it>

<https://www.unibo.it/sitoweb/g.dangelo/en>

www.unibo.it

Attributions and Notes



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

- Most of the slides are from: “**Computer Security: Principles and Practice**”, 4th global edition, W. Stallings and Lawrie Brown
- Some others are from: Dr. **Mehmet H. Gunes** (Department of Computer Science & Engineering - University of Nevada, Reno)
- Some others are from: **Mario Cagalj**, Ph.D. (Faculty of Electrical Engineering, Mechanical Engineering and Naval Architecture (FESB), University of Split)
- Some others are from: Prof. **Hossein Saiedian**, University of Kansas
- The “risk matrix” is from this [blog](#)
- I wish to **thank all of them**, **any errors that remain are my sole responsibility**